

AUDITORÍA INTERNA DE CONTROLES

CloudHealth Canarias S.L.

— Actividad Práctica de Ciberseguridad —

Autora / Auditora	María José Gómez Spandonari
Perfil	Alumna de Ciberseguridad
Empresa auditada	CloudHealth Canarias S.L.
Alcance	10 controles seleccionados del Marco Documental de Seguridad
Fecha	Julio 2026
Clasificación	Uso educativo / Portfolio profesional
Documentos relacionados	Marco Documental de Seguridad; Evaluación TPRM — TecnoSoluciones IT S.L.

PARTE 1 — OBJETIVO Y ALCANCE

El objetivo de esta auditoría interna es verificar, mediante pruebas de control y evidencia documental, si los controles definidos en el Marco Documental de Seguridad de CloudHealth Canarias S.L. se están aplicando realmente en la práctica — no solo si están documentados.

Se seleccionó una muestra de 10 controles representativos de las 5 políticas específicas del Marco Documental, priorizando aquellos directamente relacionados con las vulnerabilidades ALTAS identificadas en el análisis de riesgo inicial (cuentas de exempleados, contraseñas débiles, uso de USB personales, supervisión de proveedores).

PARTE 2 — METODOLOGÍA

Cada control se evalúa mediante tres elementos: un procedimiento de prueba (qué se hizo para verificarlo), la evidencia solicitada (qué documento o registro se pidió como prueba) y el hallazgo (qué se encontró realmente). Este enfoque asegura que cada conclusión de la auditoría sea trazable — cualquier tercero debería poder repetir la misma prueba y llegar a la misma conclusión.

Escala de resultados:

- Conforme: el control se aplica según lo documentado, con evidencia suficiente.
- Parcialmente Conforme: el control existe y se aplica de forma incompleta o inconsistente.
- No Conforme: no existe evidencia de que el control se esté aplicando.

PARTE 3 — RESULTADOS RESUMIDOS (10 CONTROLES)

ID	Control	Política de Origen	Resultado
C-01	MFA obligatorio en todas las cuentas de usuario	Política 1 — Identidades y Acceso	Parcialmente Conforme
C-02	Contraseñas de mínimo 12 caracteres aplicadas técnicamente	Política 1 — Identidades y Acceso	Conforme
C-03	Baja inmediata de cuentas al cesar la relación laboral	PRO-SEG-001 — Altas y Bajas	Conforme
C-04	Revisión trimestral de cuentas activas	Política 1 — Identidades y Acceso	No Conforme
C-05	Copias de seguridad diarias cifradas (regla 3-2-1)	Política 2 — Backups	Parcialmente Conforme
C-06	Pruebas de restauración trimestrales	Política 2 — Backups	No Conforme

C-07	Prohibición de USB personales	Política 3 — Dispositivos y Medios	No Conforme
C-08	Cifrado de tablets corporativas	Política 3 — Dispositivos y Medios	Conforme
C-09	Cláusulas de seguridad y NDA en contratos de proveedores	Política 4 — Gestión de Proveedores	No Conforme
C-10	Formación anual en ciberseguridad completada por el personal	Política 5 — Formación	Parcialmente Conforme

PARTE 4 — HALLAZGOS DETALLADOS

Se detallan a continuación los controles calificados como No Conforme, por representar el mayor riesgo y requerir acción prioritaria.

C-04 — Revisión trimestral de cuentas activas

Procedimiento de prueba:

Se solicitó evidencia documental (actas, hojas de control firmadas) de las revisiones trimestrales de cuentas exigidas por la Política 1, correspondientes a los trimestres transcurridos desde la aprobación del Marco Documental.

Evidencia solicitada:

Actas o registros de revisión de cuentas de los últimos 2 trimestres.

Hallazgo:

No se localizó ningún registro de revisión trimestral realizada. La política está documentada y aprobada, pero no existe evidencia de que se haya ejecutado ni una sola vez desde su implantación.

Resultado: No Conforme

Riesgo asociado:

Cuentas de exempleados u otras cuentas obsoletas pueden permanecer activas sin detección, ampliando la superficie de ataque — precisamente la vulnerabilidad ALTA ya identificada en el análisis inicial del Marco Documental.

C-06 — Pruebas de restauración trimestrales

Procedimiento de prueba:

Se solicitó el registro de las pruebas de restauración exigidas por la Política 2, incluyendo fecha, sistema restaurado y resultado.

Evidencia solicitada:

Registro de pruebas de restauración de backups de los últimos 12 meses.

Hallazgo:

Se confirmó que las copias de seguridad diarias sí se ejecutan (ver C-05), pero no existe evidencia de que se haya realizado ninguna prueba de restauración real. La política asume que un backup que se genera correctamente también se puede restaurar correctamente, pero esto no se ha verificado.

Resultado: No Conforme

Riesgo asociado:

Un backup nunca probado puede fallar en el momento de necesitarlo — esto es especialmente crítico dado que la organización ya sufrió un incidente de ransomware hace 6 meses, situación en la que la capacidad real de restauración es la diferencia entre una interrupción menor y una pérdida total de datos.

C-07 — Prohibición de USB personales

Procedimiento de prueba:

Se realizó una verificación puntual (spot check) en 3 puestos administrativos, inspeccionando los puertos USB y el historial de dispositivos conectados en los equipos.

Evidencia solicitada:

Inspección física y revisión del historial de dispositivos USB conectados (Visor de Eventos / registro del sistema).

Hallazgo:

En 2 de los 3 puestos revisados se detectaron conexiones recientes de dispositivos USB no correspondientes al inventario de activos corporativos. La política existe y ha sido comunicada, pero no se aplica ningún control técnico (bloqueo de puertos USB no autorizados) que la haga cumplir de forma automática.

Resultado: **No Conforme**

Riesgo asociado:

Este es el mismo vector de fuga de información ya identificado como vulnerabilidad ALTA en el análisis inicial del Marco Documental — la política por sí sola, sin control técnico que la refuerce, no ha resuelto el problema original.

C-09 — Cláusulas de seguridad y NDA en contratos de proveedores

Procedimiento de prueba:

Se solicitó el contrato vigente con el proveedor externo de TI (TecnoSoluciones IT S.L.) para verificar la existencia de cláusulas de seguridad y acuerdo de confidencialidad.

Evidencia solicitada:

Copia del contrato de servicios vigente con el proveedor.

Hallazgo:

Confirma el hallazgo ya documentado en la Evaluación TPRM de TecnoSoluciones IT S.L.: no existe un SLA de seguridad ni cláusulas específicas de ciberseguridad en el contrato actual.

Resultado: **No Conforme**

Riesgo asociado:

Ver Evaluación de Riesgo de Terceros — TecnoSoluciones IT S.L. para el análisis de riesgo completo y la hoja de ruta de remediación ya definida para este hallazgo.

PARTE 5 — RESUMEN DE CUMPLIMIENTO

Conforme	3 de 10 controles
Parcialmente Conforme	3 de 10 controles
No Conforme	4 de 10 controles
Puntuación de Cumplimiento	9 / 20 puntos (45%)

Con un 45% de cumplimiento, el estado general de los controles se considera INSUFICIENTE. Es importante contextualizar este resultado: el Marco Documental de Seguridad es relativamente reciente (implantado tras el incidente de ransomware), por lo que una brecha entre política documentada y control efectivamente aplicado es esperable en esta fase — pero requiere seguimiento activo para no convertirse en una brecha permanente.

PARTE 6 — RECOMENDACIONES PRIORITARIAS

- Ejecutar de inmediato la primera revisión trimestral de cuentas pendiente (C-04), dado que es un control ya vencido, no solo pendiente.
- Programar y documentar una prueba de restauración de backups en los próximos 30 días (C-06) — crítico dado el historial reciente de ransomware.
- Implementar bloqueo técnico de puertos USB no autorizados (C-07), en lugar de depender únicamente de la política escrita.
- Ejecutar la hoja de ruta de remediación ya definida en la Evaluación TPRM para resolver la falta de SLA con TecnoSoluciones IT S.L. (C-09).
- Establecer un calendario de auditoría interna recurrente (semestral) para evitar que los controles documentados se desvinculen de la práctica real, como ha ocurrido con varios de los controles evaluados aquí.

CONCLUSIÓN

Esta auditoría confirma que el Marco Documental de Seguridad de CloudHealth Canarias S.L. está bien diseñado, pero su implementación real presenta brechas significativas: 4 de los 10 controles evaluados no cuentan con evidencia de aplicación efectiva. Varios hallazgos — en particular el uso de USB personales y la ausencia de supervisión del proveedor externo — corresponden directamente a vulnerabilidades ya identificadas en el análisis de riesgo original, lo que indica que la existencia de una política no ha sido suficiente por sí sola para cerrar esos riesgos.

Esta auditoría, junto con la Evaluación TPRM del proveedor externo, demuestra un ciclo completo de gobernanza: identificación de riesgo → diseño de política → verificación de cumplimiento → remediación priorizada, aplicado de forma consistente sobre el mismo escenario organizativo.